

CRLF injection vulnerability #1553

✓ Closed

hannob opened on Mar 19, 2019

...

At <https://bugs.python.org/issue36276> there's an issue in Python's urllib that an attacker controlling the request parameter can inject headers by injecting CR/LF chars.

A commenter mentions that the same bug is present in urllib3:

<https://bugs.python.org/issue36276#msg337837>

So reporting it here to make sure it gets attention.

5



haikuginger on Mar 19, 2019 · edited by haikuginger

Edits ▾

Contributor

...

I confirmed that I was not able to reproduce and that the escaped CRLF was present in the querystring as of the current master. Will investigate to see what the bisection point was.



haikuginger on Mar 19, 2019

Contributor

...

Verified as fixed in [#1487](#), but that change has not been released. I recommend we release 1.24.2 with that change as soon as possible, [@sethmlarson](#) [@theacodes](#).

4



theacodes on Mar 19, 2019 via email

Member

...

I will try to cut a release soon, unless Seth wants to beat me to it. Thank you, Jess.

...



sethmlarson on Mar 19, 2019

Member

...

Without [#1531](#) or IRI support in rfc3986 releasing master in it's current state will break backwards compatibility with international URLs.



haikuginger on Mar 19, 2019

Contributor ...

I've done some checking and `requests` appears to have handling so indirect consumers via requests should not be vulnerable through us, if that's a useful datum to have.

1



vstinner on Apr 10, 2019

...

[CVE-2016-5699](#), [CVE-2019-9740](#) and [CVE-2019-9947](#) have been assigned to HTTP Header Injection vulnerabilities in Python: see <https://bugs.python.org/issue30458> for more information.



Plazmaz on Apr 16, 2019

...

I was able to reproduce this with `requests.get` using `urllib`, haven't tested with `urllib3` though.



carnil on Apr 16, 2019

...

[CVE-2019-11236](#) was assigned for this issue.



rschultheis on Apr 17, 2019

...

Hi! I've noticed that [CVE-2019-11236](#) has been assigned to the CRLF injection issue described here. It seems that the library has been patched in GitHub, but no new release has been made to pypi. Will a new release containing the fix be made to pypi soon? Based on [@theacodes comment](#) it seems like a release was going to be made, but I also see her status has her perhaps unavailable. Is someone else perhaps able to cut a new release into pypi?

1



sethmlarson on Apr 17, 2019

Member ...

[@rschultheis](#) [Per my comment](#) we cannot cut a release until IRI support is fixed in rfc3986.

1



rschultheis on Apr 17, 2019

...

Thank you [@sethmlarson](#) , I will watch that PR



vstinner on Apr 17, 2019

...

"It seems that the library has been patched in GitHub"

Do you have a reference to the change?

sethmlarson on Apr 17, 2019

Member ...

[@vstinner](#) [0aa3e24](#)

lgbaldoni on Apr 18, 2019

...

Is the problem fixed in 1.24.2? I couldn't find any reference to it in the changelog.

sethmlarson on Apr 18, 2019

Member ...

No it is not, this change will be fixed in 1.25 and is next on my list of work.

3

18 remaining items

Load more

ryanpetrello on May 1, 2019 · edited by ryanpetrello

Edits ...

[@sethmlarson](#) I'm not sure which branch I'd want to submit a PR to (sounds like I'd need you to make a `1.24-series` branch), but how do you feel about this in general?

[ryanpetrello@ 4cfdff4](#)

```
>>> urllib3.PoolManager().request(
...     'GET',
...     'http://localhost:8000/ HTTP/1.1\r\nHEADER: INJECTED\r\nIgnore:'
... )
Traceback (most recent call last):
  File "<stdin>", line 3, in <module>
  File "/home/ryanpetrello/dev/urllib3/src/urllib3/request.py", line 68, in request
    **urlopen_kw)
  File "/home/ryanpetrello/dev/urllib3/src/urllib3/request.py", line 89, in request_encode_u
    return self.urlopen(method, url, **extra_kw)
  File "/home/ryanpetrello/dev/urllib3/src/urllib3/poolmanager.py", line 312, in urlopen
    u = parse_url(url)
  File "/home/ryanpetrello/dev/urllib3/src/urllib3/util/url.py", line 162, in parse_url
    raise ValueError("URL can't contain control characters. {}".format(url))
ValueError: URL can't contain control characters. http://localhost:8000/ HTTP/1.1
```

HEADER: INJECTED
Ignore:

sethmlarson on May 1, 2019

Member ...

I would raise a `LocationParseError` instead of raising a `ValueError` but besides that it looks fine. Maybe we'd want to put a note that this is taken from cpython as well. We'd also need some test cases for each control character.

ryanpetrello on May 1, 2019 · edited by ryanpetrello

Edits ...

@sethmlarson if you'll create a 1.24 series branch, I'll open a PR based on this (with some tests).

sethmlarson on May 1, 2019

Member ...

[I created the branch.](#)

  **ryanpetrello** mentioned this [on May 1, 2019](#)

 [prevent CVE-2019-9740 in 1.24.x #1591](#)

  **rfultz** mentioned this [on May 1, 2019](#)

 [\[HIGH\] CRLF injection -- need a fix by May 24, 2019 fecgov/fec-cms#2862](#)

ryanpetrello on May 3, 2019

...

An FYI for those in this thread: a resolution has also been merged into the 1.24 series and released as 1.24.3:

[#1593](#)

<https://github.com/urllib3/urllib3/releases/tag/1.24.3>

  **Kronopt** mentioned this [on May 3, 2019](#)

 [avoid CVE-2019-9740 in 1.24.x by percent-encoding invalid path characters #1593](#)

  **ofek** mentioned this [on May 16, 2019](#)

 [Upgrade requests to 2.22.0 DataDog/integrations-core#3778](#)

  **zabbal** mentioned this [on May 21, 2019](#)

 [Bump urllib3 version requirements advancedtelematic/python-hereos-ingestion#1](#)

  **ryanpetrello** mentioned this [on Jun 7, 2019](#)

 [Tower modules ansible/awx#4025](#)



pkfec mentioned this in 3 issues [on Aug 20, 2019](#)



[\[Synk: High\] CRLF injection and Improper Certificate Validation found in urllib3 \[due: 9/5/2019\] fecgov/openFEC#3897](#)



[\[Snyk: High\] CRLF injection found in urllib3 \[due: 9/5/2019\] fecgov/openFEC#3896](#)



[\[Snyk: High\] urllib3 vulnerability \[due 9/5/2019\] fecgov/openFEC#3893](#)



damarisg mentioned this [on Jul 19, 2022](#)



[Release 4.3.6 - Release Candidate 1 - E2E UX tests - Vulnerability Detector wazuh/wazuh-qa#3106](#)

Sign up for free

to join this conversation on **GitHub**. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

No labels

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development



Code with agent mode



No branches or pull requests

Participants



+6

